BSIDES LUXEMBOURG · 2026

Your CTI Reports Are Useless Without Structure

From unstructured threat intel to **STIX knowledge graphs** — with LLMs and an **MCP**
an **MCP** server.

ANTONIO FORMATO · CYBERSECURITY SOLUTION ENGINEER @ MICROSOFT · INDEPENDENT CTI RESEARCHER

TI-MINDMAP-HUB.COM

In 2012, the Hubble Space Telescope revealed **Styx** — a tiny moon orbiting Pluto that had been hiding in plain sight for **billions of years**.

It took a better instrument to see what was already there.

In 2026, we have a similar problem with threat intelligence intelligence — the connections between reports are already already there. We just need better instruments to see them. see them.

ROADMAP

Three instruments, one mission

Make CTI consumable, structured, and actionable — for humans and for agents.

01 — STRUCTURE

STIX 2.1 + hybrid LLM

EXTRACT

Turn unstructured prose into machine-readable readable bundles.

02 — PLATFORM

Multi-lens workstation

CONSUME

Same intelligence, different analytical lenses for humans.

03 — ACCESS

MCP + STIX Constellation

CONNECT

Expose intelligence to agents — reveal the cross-report graph.

THE VOLUME PROBLEM

Every week, the CTI community publishes hundreds of stories

Your SIEM, your TIP, and your AI copilot can consume **exactly zero** of them.

~hundreds

threat reports / week

OSINT — vendors · govs · researchers · blogs

HOW IT'S SHIPPED

Blog posts — narrative HTML, IOCs scattered in prose, no consistent schema schema across vendors

IOC parsing nightmare — defanging inconsistent (hxxp, [.], (dot), [at]), mixed in [at]), mixed in tables, lists, and inline text

PDF reports — multi-column layouts, IOCs split across pages, tables that break that break on extraction

No STIX, no MISP, no feed — structured intel exists, but rarely at the source source

STANDARDS

STIX 2.1 should already be the answer

Mature, graph-native, OASIS-standardized. Adopted in pockets — skipped at scale.

WHERE IT WORKS

Mature consumers

CISA AIS, NCSC, national CERTs

ISACs and sector-specific feeds

TIPs (MISP, OpenCTI, EclecticIQ)

TAXII pull/push between trusted partners

WHY IT STALLS

Friction at the edge

Manual conversion is slow, dull, expensive

Requires deep STIX/ATT&CK domain expertise

Most threat intel is born as prose, not graph

Each report ends as a one-off PDF — never reused

— ACT 01 —

Structure

From unstructured reports to STIX 2.1 bundles, with hybrid LLM extraction — and the academic benchmark that proves it works.

PRIMER

STIX 2.1 in 90 seconds

A graph language for cyber threat intelligence — Graph Native

DOMAIN OBJECTS

SDO

the WHO, WHAT, WHY

```
Threat Actor
Malware
Attack Pattern
Campaign
Identity
Vulnerability
```

CYBER-OBSERVABLES

SCO

the technical evidence

```
IPv4-Addr
File
Domain-Name
URL
Network-Traffic
```

RELATIONSHIP OBJECTS

SRO

the connective tissue

```
uses
attributed-to
targets
indicates
derived-from
```

A `STIX Bundle` = a JSON document that wraps these typed nodes and edges into a portable graph.

ARCHITECTURE

The hybrid GenAI–STIX pipeline

Deterministic where precision matters. LLM where semantics matter.

01 · INGEST	02 · IOC	03 · SCO	04 · SDO	05 · SRO	06 · BUNDLE
URL / PDF / HTML	**Regex + LLM**	**Programmatic**	**LLM semantic**	**LLM relations**	**Validate +**
→ Markdown	contextual validation	stix2 objects	extraction	uses / targets / …	serialize

DETERMINISTIC

IOCs (IPs, hashes, domains, URLs) — Regex + iocextract. **Zero hallucination tolerance.**

LLM

TTPs, threat actors, malware families, relationships — LLM with role + few-shot + JSON mode.

https://github.com/GiulioTriggiani/STIX-2.1-Generator/blob/main/GenAI_STIX_2_1_Generator_V13.ipynb

Blog post processing pipeline

From OSINT source to analyst-ready intelligence artifacts — four phases, parallel branches.

LLM · DETERMINISTIC · HYBRID · OUTPUT

ENTRY

- OSINT sources + analyst submissions
- Acquisition — Steel Browser / BS4
- Normalization — HTML→Markdown · Dedup

ANALYSIS

- IOC extract — Regex + LLM
- TTP → ATT&CK — LLM extract + order
- CVE correlate — Regex + CIRCL API
- Actor / malware — LLM entity extract

STRUCTURE

- STIX 2.1 bundle — Assembly
- Summary + mindmap — LLM creative output
- Knowledge artifacts — 5W + dashboard

OUTPUTS

- Intel Graph + STIX JSON
- Diamond + Attack Flow
- AI Summary + Mindmap
- IOC Table + Export
- CVE Risk + Refs
- TTP Catalog + Heatmap
- 5W Context + Source

STIX 2.1 bundle generation

From raw article to a structured threat intelligence graph — 9 steps, 7 LLM calls, 10 STIX object types.

STEP 0 · RETRIEVE
Article + IOCs
CVEs · TTPs
Blob + Cosmos DB

STEP 1 · IDENTITY
Author + Org
TLP:CLEAR
First 2000 chars

STEP 2 · FILTER
Confidence ≥ med
Domain whitelist
CVE → vuln map

STEPS 3–5 · EXTRACT
Attack patterns
Malware · Actors
Tools (dual-use)

VALIDATE
MITRE ID regex
Dedup by name
Pydantic schemas

STEP 6 · RELATIONSHIPS

LLM-driven
IOC→Malware
Malware→TTP

Deterministic (all-to-all)
Actor→Malware · Actor→TTP · Actor→Tool
Malware→Vuln · Malware→Tool · IOC→Vuln

STEPS 7–8 · ASSEMBLE
Report object
Bundle · spec 2.1
Dedup relationships

STEP 9 · PERSIST
Cosmos DB
Azure Blob
stix_bundle.json

7	10	9	0.1	2.1
LLM Calls	Object types	Relationship types	Temperature	STIX spec

METHODOLOGY

How we measured it: an academic collaboration

Joint work with the University of Salerno — peer-reviewable, ground-truth, reproducible.

ACADEMIC SUPERVISOR

Prof. Arcangelo Castiglione

University of Salerno

IMPLEMENTATION LEAD

Giulio Triggiani

MSc thesis candidate

CO-ADVISOR

Antonio Formato

TI Mindmap HUB

THESIS

Automated CTI via LLMs: design, implementation, and comparative benchmarking for STIX 2.1 bundle generation.

20 NCSC ground-truth bundles

Dual evaluation pipeline (object + graph)

Academic paper currently under peer review

EVALUATION PROTOCOL

Dual evaluation methodology

One pipeline scores what was extracted. The other scores how the graph holds together.

PIPELINE 1 · SEMANTIC

Did we extract the right objects?

Per-object comparison against ground truth using `object_similarity` and `object_equivalence` → from cti-python-stix2 library

- Object equivalence — SDO / SCO
- Custom comparison — SRO
- True / false positives, false negatives
- **Metrics:** Precision · Recall · F1 — separate for SDO/SCO and SRO SRO

PIPELINE 2 · GRAPH

Does the whole graph hold together?

Whole-bundle similarity using `graph_similarity` and `object_equivalence` → from cti-python-stix2 library

- Graph Similarity Score
- Aggregate metrics across the corpus
- **Metric:** structural fidelity of the bundle as a whole

BENCHMARK

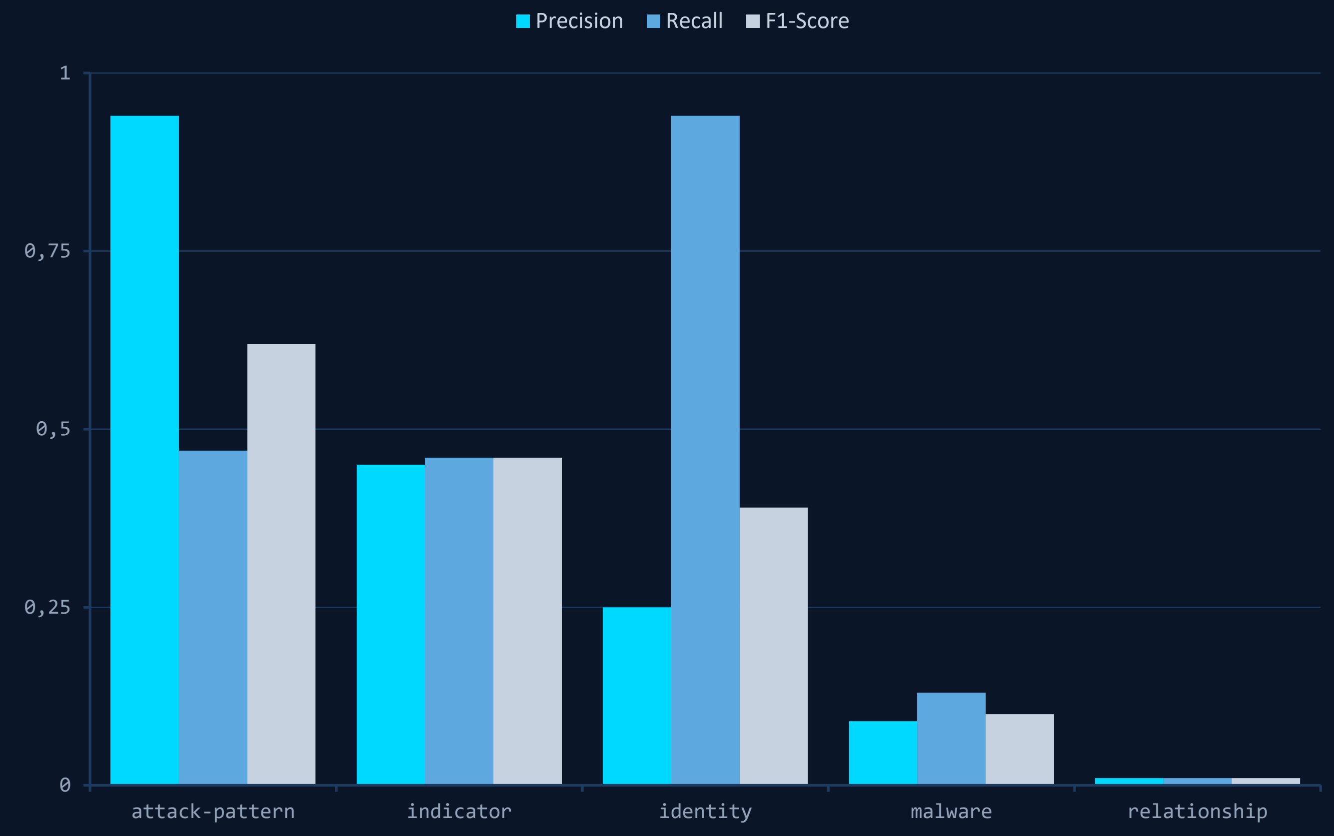
Five model families on the line

Top setup per family. Low temperature / high reasoning. Identity recall is solved; structural F1 separates the field.

MODEL	SETUP	TTP PRECISION	TTP F1	IDENTITY RECALL	INDICATOR F1
GPT-5	High Reasoning	93.8%	62.4%	93.8%	45.4%
Gemini 2.5 Pro	High Reas. / T 0.1	94.2%	62.3%	100.0%	46.0%
GPT-4.1	Temp 0.1	68.3%	45.2%	100.0%	44.0%
Llama 4 Maverick	Temp 0.1	55.8%	36.6%	100.0%	48.3%
Llama 3.3	Temp 0.1	7.0%	4.4%	100.0%	38.5%

low T / high reasoning gives the best F1 — high T adds noise, not value.

PERFORMANCE BY STIX OBJECT TYPE



Identity recall >88% — victim detection is solved.

Lower precision = cautious model: over-extracts context to avoid missing victims.

Indicator F1 stable at 45–48% — IOC extraction is not LLM-only; the pipeline holds even on weaker models.

https://github.com/GiulioTriggiani/STIX-2.1-Generator/blob/main/GenAI_STIX_2_1_Generator_V13.ipynb

— ACT 02 —

Platform

Structure is not enough. Intelligence must be consumable — for humans through visual lenses, for agents lenses, for agents through conversational tools.

THE PLATFORM

TI Mindmap HUB — the living research lab.

Independent research platform · OSINT-only · agent-first by design

1.3k+

REPORTS

processed from +280 unique sources

1k+

STIX BUNDLES

STIX objects generated

18k+

IOCS

IPs · hashes · domains · URLs

600+

CVES

tracked, avg CVSS 8.2

50–60 new reports processed per week via automated multi-agent ingestion pipeline. pipeline.

Narrative Markdown + structured JSON — published every Monday on Medium, with matching STIX artifacts.

VISUAL LENSES

One report, more than six analytical lenses.

Same structured intelligence, different shapes for different analyst questions.

01 · MINDMAP

Entity / relationship

Mermaid bases map

02 · DIAMOND

Adversary model

Adversary · infrastructure · capability · victim.

victim.

03 · ATT&CK

MITRE coverage

Behavioral coverage across tactics & techniques.

techniques.

04 · TIMELINE

Attack chain

Step-by-step, ordered.

05 · CVE

Vulnerabilities

Prioritized with threat context.

06 · NARRATIVE

Markdown brief

Executive & analyst consumption.

All six lenses are generated from the same STIX bundle. No duplicate extraction. No drift between views.

https://ti-mindmap-hub.com

- IOC Search
- CVE Search
- STIX Bundles
- Statistics
- MCP Server
- Agentic Reports
  AI-generated threat analysis
- Research Project
- Submit Article
- Roadmap
- STIX Constellation
  Knowledge graph explorer
- About

SUPPORT & LINKS

- Feedback
- GitHub Repository
- Documentation
- Terms of Service
- Privacy Policy

Independent research project. AI-generated content requires verification.

Source: mp.weixin.qq.com
Published: May 5, 2026
vendor
View AI Analysis | Source

Source: opensourcemalware.com
Published: May 5, 2026
vendor
View AI Analysis | Source

Source: blog.pulsedive.com
Published: May 4, 2026
vendor
View AI Analysis | Source

AI Analyzed

Breaking the code: Multi-stage 'code of conduct' phishing campaign leads to AiTM token...

A sophisticated, multi-stage phishing campaign disguised as a corporate 'code of conduct' update is compromising user credentials and session tokens through adversary-in-the-middle (AiTM)...

Source: www.microsoft.com
Published: May 4, 2026
vendor
View AI Analysis | Source

AI Analyzed

Phishing campaigns and BEC attacks through Amazon SES | Securelist

Attackers are increasingly abusing Amazon SES by hijacking leaked AWS credentials to send highly convincing phishing and BEC emails that bypass traditional security checks, exploiting trusted infrastructu...

Source: securelist.com
Published: May 4, 2026
vendor
View AI Analysis | Source

AI Analyzed

Proof-of-concept exploit available for Linux 'Copy Fail' vulnerability (CVE-2026-31431)

A newly disclosed, high-severity Linux vulnerability (CVE-2026-31431) with public exploit code allows unprivileged users to gain root access on most modern distributions, making urgent patching essential.

Source: www.sophos.com
Published: May 3, 2026
vendor
View AI Analysis | Source

AI Analyzed

Debian Linux Patched Copy Fail (CVE-2026-31431) Vulnerability

A critical kernel bug in Debian allowed any local user to instantly gain root access, prompting urgent security patches that must be applied to prevent undetectable privilege escalation attacks.

Source: ostechnix.com
Published: May 3, 2026
vendor

AI Analyzed

Exploit Fail: Why CVE-2026-31431 (Copy Fail) barely scratches Talos Linux

Despite affecting Talos Linux's kernel, the CVE-2026-31431 "Copy Fail" exploit poses minimal practical risk due to Talos's unique security defaults and absence of vulnerable binaries, but users should still...

Source: www.siderolabs.com
Published: May 3, 2026
vendor

AI Analyzed

Linux Kernel "Copy Fail" Local Privilege Escalation (LPE), CVE-2026-31431, Under Active Exploitation

A newly discovered and actively exploited Linux kernel vulnerability, "Copy Fail" (CVE-2026-31431), allows any local user—including those inside containers—to reliably escalate to root by corrupting in-memor...

Source: xmcyber.co
Published: May 3, 2026
vendor

DISTRIBUTION

Humans aren't the only consumers anymore.

If your intelligence is only readable by humans, your agents don't have it.

FOR HUMANS

- Six analytical lenses (previous slide)
- Weekly Threat Briefing on Medium
- Web platform + GitHub docs
- Telegram bot for mobile queries (beta)

FOR AGENTS

- MCP server — 25 tools, OAuth 2.1
- Native tool calls for Claude, Copilot, ChatGPT,...
- STIX bundles as structured context
- Agent-first by design, not retrofit

MODEL CONTEXT PROTOCOL

MCP — intelligence as tool calls.

The Model Context Protocol turns any CTI platform into a first-class citizen of the agent stack.

REPORTS

search reports · list by source · filter by date, TLP, ATT&CK

IOC PIVOTS

"where else has this IOC been seen?" · STIX bundle retrieval for any report
report

CONTENT

get full report content · extract ATT&CK heatmap · pull IOC feeds by format
format

CONSTELLATION

graph traversal · canonical entity search · cross-report relationships

AGENT IN ACTION

Natural language.
Structured answers.

The analyst asks in English. The agent calls MCP tools.

The response comes back with real STIX underneath.

ANALYST PROMPT

Retrieve recent TI Mindmap HUB reporting on North Korea–
Korea–attributed npm supply chain attacks. Summarize key
Summarize key findings and produce a table listing each
each report with source attribution, and flags for IOC and CVE
and CVE coverage

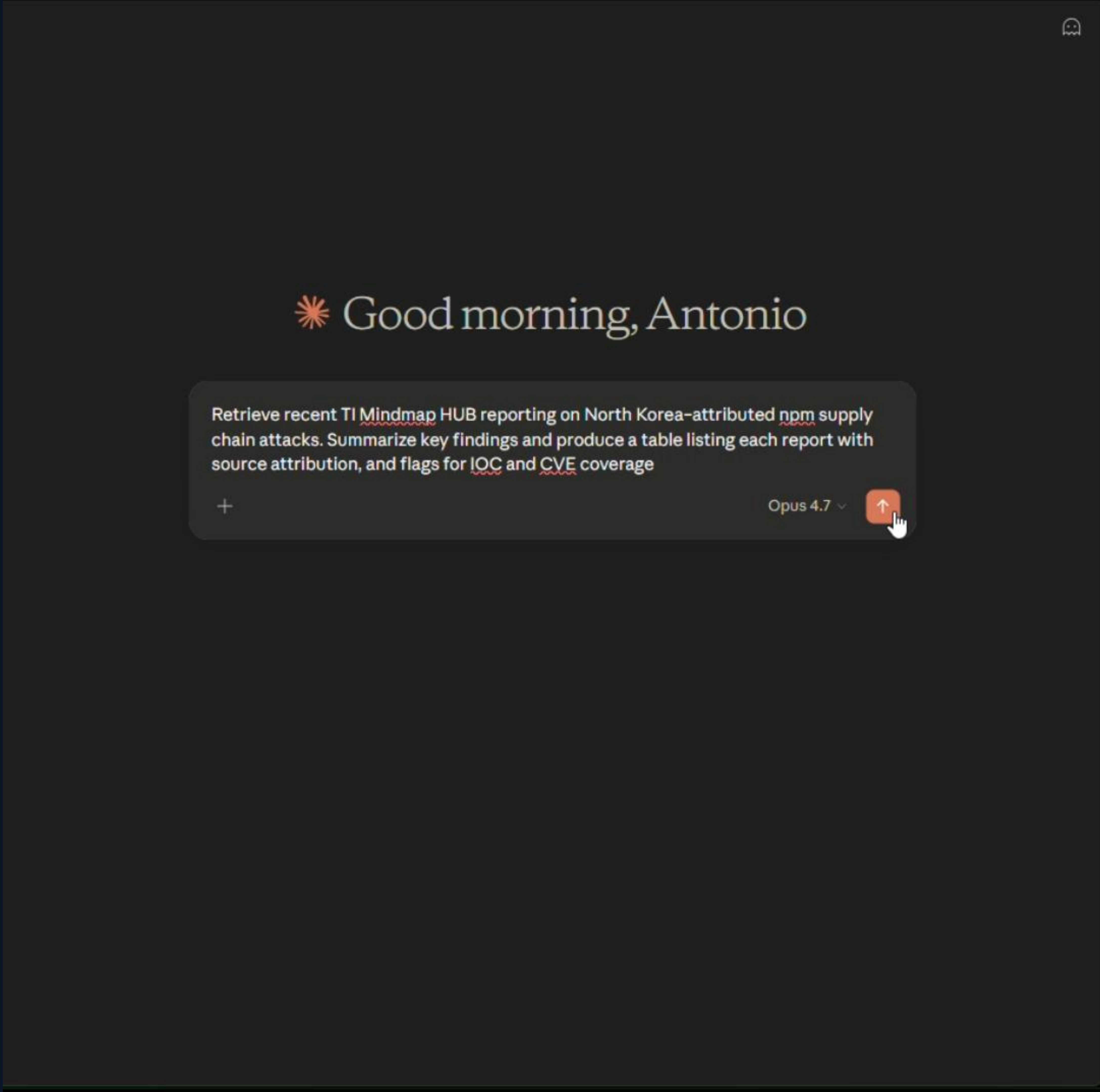
→ calling tool_search(query="threat intel reports")

→ calling list_reports(search="Axios npm", time_range="30d")

→ calling get_report_details(report_id="338b8d6c…") ×7

→ fetching IOC + CVE blobs · 7 sources · 0 CVEs · 77 IOCs

→ returning structured briefing + attribution table



— ACT 03 —

One bundle tells you a story. Hundreds of bundles, connected, tell you a you a sky

THE GAP

Every STIX bundle is an island

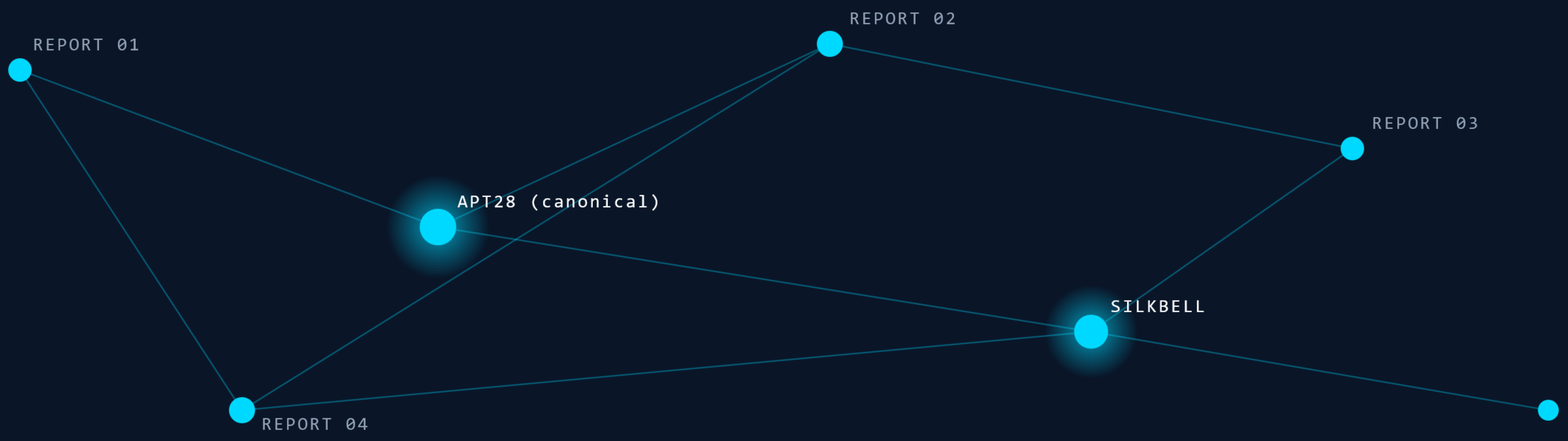
TI Mindmap HUB processes each report in isolation. Cross-report context is missing by default.

REPORT A	REPORT B	REPORT C	REPORT D
APT28 / Sofacy	Fancy Bear	Forest Blizzard	Strontium

Same actor. Four names. Four disconnected bundles. No graph.

The STIX Constellation

Every STIX bundle is a moon. Connect enough moons and you see the gravitational system that binds them.



ARCHITECTURE

Two-layer architecture

Raw mentions stay immutable. A canonical layer sits on top, linked back by reversible edges.

LAYER 1 · MENTIONS

Raw evidence

Every entity exactly as extracted from each report. One "APT28" per report = one mention node. **Immutable source of truth.**

LAYER 2 · CANONICAL

Deduplicated view

Fancy Bear + APT28 + Forest Blizzard collapse to **one** to **one canonical Threat-Actor** . Linked back via via `:RESOLVES_TO` edges with score + method + + version.

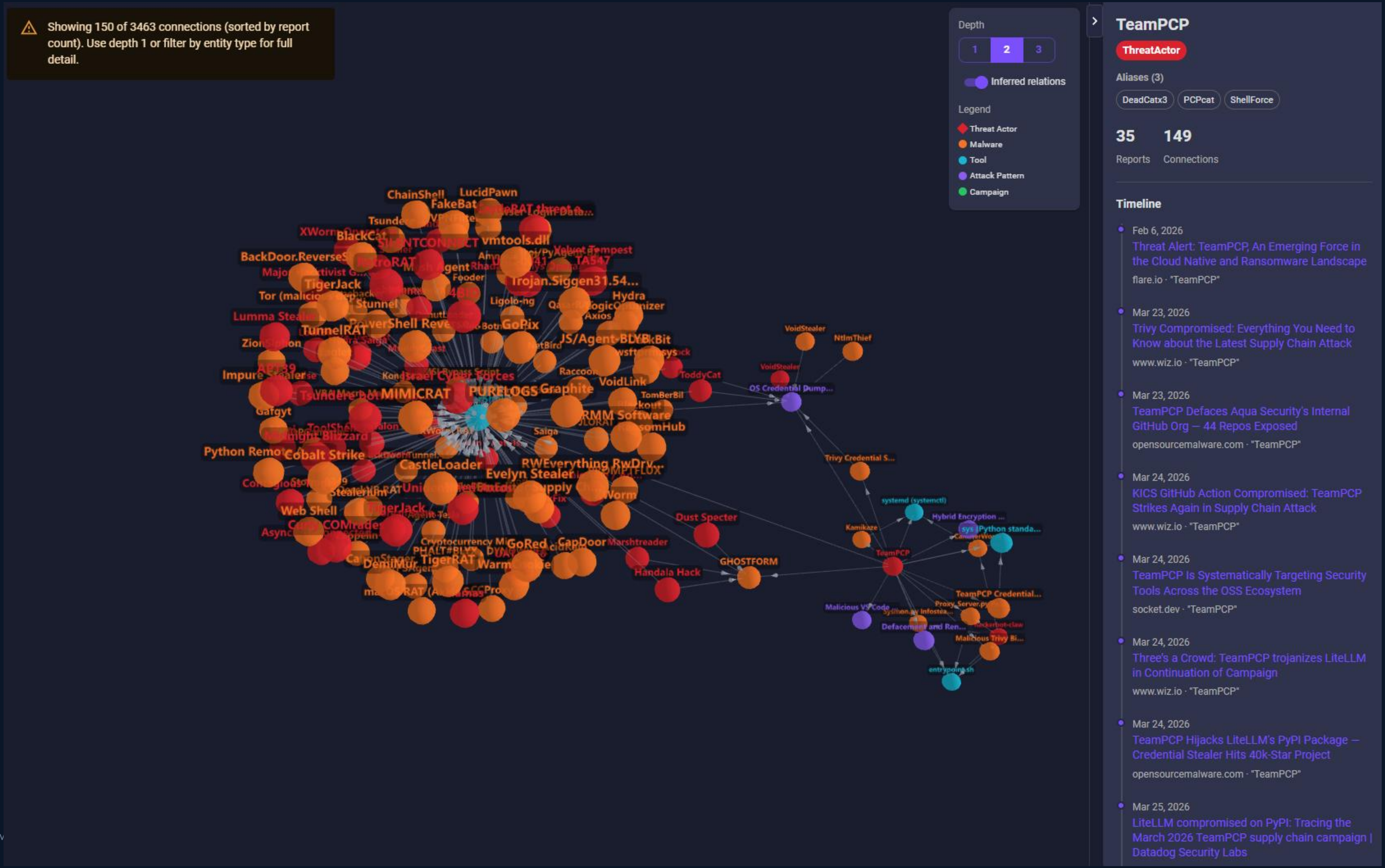
EDGES · CROSS-REPORT

LLM-derived relations

`:OBSERVED_REL` (stated) vs `:INFERRED_REL` (LLM-derived, with confidence). Temporal aggregation across the corpus.

Reversible by design: if entity resolution gets it wrong, we roll back by deleting an edge — never by rebuilding nodes.

Constellation in production



HONEST ASSESSMENT

What's working — and what isn't yet

This is where collaboration matters most.

WORKING

- Entity resolution with IOC-hardening guard
- Alias tables for top-100 known threat actors
- Reversible merge architecture validated
- 6 KG tools exposed via MCP, verified in production
- 59.7% compression on a live corpus

OPEN PROBLEMS

- Inference precision at scale (46 today, need 1000s)
  1000s)
- Temporal reasoning — what happened when?
- Multi-agent validation for adversarial LLM injection
- Conflict resolution across contradicting reports
- Making the graph itself analyst-queryable visually

BRINGING IT BACK

HUBBLE didn't put Styx in orbit. It revealed it.

STIX + LLM don't invent the connections. They reveal what was already there.

THE WORK is what we do with what we now see.

CALL TO ACTION

Come build this with me

Independent research. Open to collaboration. Not a product.

WEB

ti-mindmap-hub.com

github.com/TI-Mindmap-HUB-Org/ti-mindmap-hub-research

medium.com/ti-mindmap-hub-research

FIND ME

LinkedIn https://www.linkedin.com/in/antonioformato/

Medium · https://medium.com/@antonio.formato

X · @anformato

Thank you. Questions?

TI Mindmap HUB is a personal, independent research project — not affiliated with any employer or commercial entity.

entity.